IAM: OneLogin, permisos y ciclo de vida

2 de octubre de 2026

Objetivo y reparto

Conectar OneLogin con la aplicación para demostrar identidad real, MFA, permisos por puesto y altas/bajas automáticas. No sustituirlo por otro proveedor ni por una pantalla de login creada por el grupo.

IAM tiene cinco puestos: coordinación de roles, conexión OneLogin, MFA y ciclo de vida, pruebas de aprovisionamiento y documentación técnica. Asignar cada función en el control privado.

Laptop IAM 1: administración. IAM 2: navegador de pruebas, con perfiles separados para ingeniero, auditor y usuario sin permiso.

Antes de iniciar

Necesitan tenant OneLogin, cuenta administrativa autorizada, aplicación HTTPS activa y capacidad de aprovisionamiento en el plan disponible. Confirmar estas funciones al principio. El acceso de prueba no garantiza todas las funciones: si faltan, solicitar a la institución habilitación o el entorno adecuado.

Recibir de TI APP_BASE_URL y SCIM_TOKEN. Estos son datos de configuración; el token no debe aparecer en capturas. Las operaciones se hacen sobre cuentas de laboratorio.

Paso 1. Crear usuarios de prueba

1. Abrir el portal administrativo del tenant.
2. Ir a Users → Users y crear las identidades del recorrido según el registro de RRHH.
3. Usar el mismo correo en OneLogin, Microsoft 365 y el registro. No es sincronización automática: son cuentas relacionadas por acuerdo.
4. Registrar LAB-INGENIERO para ingeniero, LAB-ADMIN para administrador y LAB-AUDITOR para auditor.
5. Preparar también una identidad sin permiso y otra temporal para alta/baja, si los recursos lo permiten.
6. Hacer que cada usuario establezca su contraseña de laboratorio y registrar quién es responsable de su método MFA.

Paso 2. Definir atributos y roles

Crear campos de usuario lab_role y emp_id mediante la opción de campos personalizados del tenant. Registrar sus nombres cortos exactamente así.

Identidad	lab_role	Uso
LAB-INGENIERO	mantenimiento	Consultar y ejecutar mantenimiento
LAB-ADMIN	admin	Consultar, mantener, administrar y ver registros
LAB-AUDITOR	auditor	Consultar y ver registros; sin mantenimiento
Usuario de consulta	consulta	Solo consultar
Usuario sin acceso	sin_acceso	Ninguna función

El valor title que recibirá la aplicación por SCIM transporta el código lab_role en este ejercicio. No es el nombre humano del puesto. El puesto completo permanece en RRHH.

Crear roles en Users → Roles: LAB-Mantenimiento, LAB-Administracion, LAB-Auditoria y, si se usa, LAB-Consulta. Un rol OneLogin agrupa aplicaciones permitidas; la aplicación comprueba las funciones internas usando el atributo sincronizado.

Paso 3. Crear conector de inicio de sesión

1. Ir a Applications/Apps → Add Apps y localizar el conector OpenID Connect (OIDC) de OneLogin.
2. Nombrarlo IDENTITY ACCESS LAB - Servidor.
3. Configurar el flujo Authorization Code para una aplicación con servidor. No usar Password Grant ni un secreto dentro del navegador.
4. Registrar callback exacto: APP_BASE_URL/auth/callback.
5. Registrar URL de inicio como APP_BASE_URL/login si el conector solicita Login URL.
6. Copiar Client ID y Client Secret al responsable de TI para .env.
7. Copiar la dirección de configuración del proveedor OIDC. Para API v2 suele usar /oidc/2/ .well-known/openid-configuration; confirmar con el tenant.
8. Verificar método de autenticación del cliente. Authlib usa el método compatible configurado; si el tenant exige POST y rechaza Basic, TI debe configurar token_endpoint_auth_method= 'client_secret_post' en client_kwargs.
9. Asociar esta aplicación a los roles de laboratorio autorizados.

Resultado: al pulsar login en la aplicación, aparece la página real de OneLogin. Todavía puede haber rechazo al volver si la cuenta no ha sido creada por SCIM.

Paso 4. Configurar MFA OneLogin

1. Abrir Security → Authentication Factors y habilitar OneLogin Protect u otro factor aceptado por el tenant.
2. Crear una política de usuario para el laboratorio en Security → Policies.
3. En su apartado MFA, exigir verificación en cada login para la demostración, cuando aparezca la opción At every login.
4. Asociar la política a los usuarios de prueba mediante el grupo o configuración de usuario correspondiente.

5. En IAM 2, iniciar sesión con el ingeniero y registrar el factor en su teléfono.
6. Cerrar sesión de OneLogin y aplicación, abrir un perfil limpio y repetir.
7. Guardar evidencia del desafío y resultado. No fotografiar QR de inscripción ni códigos secretos.

El método puede estar en un teléfono distinto del usado como cámara. Si comparten dispositivo, comprobar que cambiar a la app MFA no detiene la cámara antes del ensayo.

Paso 5. Crear conector de altas y bajas

El servidor incluido implementa el perfil de práctica SCIM Core 1.0 del conector documentado de OneLogin. No se presenta como una implementación completa de SCIM 2.0.

1. Añadir SCIM Provisioner with SAML (Core Schema) y nombrarlo IDENTITY ACCESS LAB - Provisioning.
2. Usar solo su función de aprovisionamiento. El login sigue siendo OIDC; no configurar una URL SAML inexistente para aparentar SSO.
3. En Configuration, colocar SCIM Base URL: APP_BASE_URL/scim/v1.
4. Colocar el token que TI guardó como SCIM_TOKEN.
5. Pegar el archivo Implementacion/app/scim-template.json como plantilla.
6. En Parameters, mapear scimusername al correo, lab_role al campo personalizado correspondiente y emp_id al ID de empleado. Si faltan parámetros, agregarlos y habilitar su inclusión en el aprovisionamiento según la interfaz.
7. No activar sincronización de grupos: el ejemplo sincroniza usuarios y su rol, no grupos.
8. Habilitar la conexión y revisar API Status. Si falla, comprobar la URL HTTPS, token y registros del servidor.
9. En Provisioning, habilitar creación y actualización de usuarios. Para la baja, seleccionar suspensión/desactivación de cuenta y probar qué envío realiza el conector.
10. Asociar este conector a los mismos roles de laboratorio que el OIDC.

La aplicación admite GET/POST de usuarios, consulta por userName, actualización PUT/PATCH y eliminación. Acepta active:false y niega acciones a cuentas inactivas. Si se activa una función distinta, como grupos, hay que implementar y probar esa extensión antes de declararla soportada.

Paso 6. Automatizar asignación

En Users → Mappings, crear condiciones según el atributo lab_role y asignar el rol OneLogin correspondiente. Ejemplo: si lab_role es mantenimiento, asignar LAB-Mantenimiento, que incluye ambos conectores.

1. Guardar la regla.
2. Aplicarla al usuario de prueba y comprobar el rol resultante.
3. Revisar opciones de retirar roles que dejan de cumplir condiciones. No asumir que una regla solo de alta retira automáticamente un permiso viejo.
4. Para el primer ensayo, se puede aprobar manualmente una operación pendiente en Users → Provisioning.
5. Para demostrar automatización completa del laboratorio, configurar las aprobaciones permiti-

das en ese conector de prueba y repetir una nueva alta sin crear la cuenta manualmente en la aplicación.
6. Registrar si la acción fue automática o si requirió aprobación administrativa. La aprobación no equivale a una creación manual de cuenta, pero debe explicarse.

Paso 7. Probar alta automática

1. Confirmar que el correo temporal no existe en la aplicación.
2. Crear o activar el usuario en OneLogin con sus atributos.
3. Dejar que Mapping asigne su rol o realizar la asignación de rol acordada.
4. Revisar Users → Provisioning hasta que el evento esté completado.
5. TI confirma que se creó el usuario local y SOC guarda el evento SCIM_CREATE.
6. Iniciar sesión por OIDC y ejecutar consulta y mantenimiento según rol.

Una cuenta creada a mano en SQLite o por un curl de prueba no demuestra alta automática desde OneLogin.

Paso 8. Probar autorización

Usuario	Acción	Resultado esperado
Ingeniero	Consulta	Permitido
Ingeniero	Mantenimiento	Permitido
Ingeniero	Administración	403, denegado
Auditor	Consulta y registros	Permitido
Auditor	Mantenimiento	403, denegado
Sin aplicación asignada	Login/aplicación	Rechazo según control de OneLogin o aplicación

Probar con botón o petición real, no solo mirando la pantalla. Para el auditor, el botón mantenimiento se deja visible intencionalmente y el servidor debe rechazarlo.

Paso 9. Probar cambio y baja

1. Cambiar lab_role de mantenimiento a auditor en OneLogin.
2. Comprobar actualización local por SCIM.
3. Sin cerrar la sesión anterior, intentar mantenimiento: debe ser rechazado después de recibir la actualización.
4. Probar consulta y registros permitidos.
5. Desactivar el usuario según la solicitud de RRHH.
6. Esperar y registrar el evento de suspensión recibido, con su hora real.
7. Probar acción en sesión previa y nuevo login. La aplicación consulta el estado local en cada acción; tras recibir la baja, la sesión anterior no permite ejecutar funciones.
8. Verificar baja en Microsoft 365 y RFID con los otros departamentos. Esas acciones no ocurren automáticamente por configurar SCIM de esta aplicación.

Comprobaciones técnicas

TI puede comprobar /health sin credenciales. Una consulta SCIM sin token debe devolver 401:

```
curl -i http://127.0.0.1:8000/scim/v1/Users
```

En la terminal donde TI cargó .env, consultar un correo de laboratorio:

```
curl --get http://127.0.0.1:8000/scim/v1/Users \
  -H ”Authorization: Bearer ${SCIM_TOKEN}” \
  --data-urlencode 'filter=userName eq ”REEMPLAZAR_CORREO”'
```

No pegar el token literal en capturas. Si devuelve totalResults:0, la cuenta no llegó o se usó otro correo. Si hay 401, revisar token. Si la conexión da 502, revisar Gunicorn y túnel.

Entregan

Tabla de roles, configuración OIDC, configuración SCIM sin secretos, reglas, evidencia MFA, altas, cambios, bajas y eventos OneLogin. Escribir cuáles acciones fueron automáticas y cuáles manuales.

Referencias y videos

- OneLogin: conectar aplicación OIDC.
- OneLogin: configuración del proveedor.
- OneLogin: esquema de usuarios SCIM.
- OneLogin: implementar API SCIM.
- OneLogin: crear aplicación SCIM de prueba.
- OneLogin: agregar MFA.
- Video oficial: grupos, roles y mappings.
- Video oficial: ciclo de vida, parte 2.